

System Review & Audit Report - STELA Project

Role: Senior System Developer

Date: September 2026

1. Top 10 Kekurangan STELA

- Arsitektur Tidak Standar (Spaghetti Code):** Logika bisnis dan tampilan (HTML/UI) dicampur dalam satu file (contoh: `reports.php`), melanggar pola MVC.
- Keamanan (SQL Injection Risk):** Penggunaan raw SQL dengan `$db->escapeString()` alih-alih *Prepared Statements* (PDO).
- Duplikasi Kode (WET):** Banyak fungsi JS dan blok HTML disalin-tempel ke berbagai file.
- Hardcoded Business Logic:** Penentuan scope kerja (MSM/TTN) dilakukan dengan `strpos()`, bukan data tabel.
- Penanganan Error Buruk:** Penggunaan `die()` di production code merusak UX.
- Performa (N+1 & Memory Issues):** Penggunaan `SELECT *` pada laporan dan tidak ada **caching**.
- Tidak Ada Testing:** Tidak ada unit test atau integration test.
- Manajemen State RBAC Rentan:** Hanya mengandalkan string role di session alih-alih sistem ACL.
- Pencarian Kurang Efisien:** Murni mengandalkan klausa `LIKE` di SQL, tanpa Elasticsearch.
- Belum Siap Production:** Konfigurasi `.env` dan **error reporting** belum diarahkan ke log terpusat.

2. Rincian Temuan & Audit

Architecture & Struktur Folder

- Masalah:** Query dieksekusi langsung di View.
- File & Line:** `resources/user/reports.php` (Line 10-30).
- Dampak:** Sulit di-maintenance, merusak testing, blocking rendering.
- Solusi:** Refactor ke pola MVC. Pindahkan logika ke Controller/Model.
- Prioritas:** Critical

Code Quality & Duplicate Code

- **Masalah:** Duplikasi fungsi `toggleSection` dan HTML tabel.
- **File & Line:** `reports.php` di `admin`, `user`, `dept`.
- **Dampak:** Rawan **human error** saat update fitur.
- **Solusi:** Buat file **partial/component** atau **helper** UI.
- **Prioritas:** Medium

Database & N+1 Query

- **Masalah:** Query kompleks `SELECT` * berulang.
- **File & Line:** `dept/reports.php` (Line ~50).
- **Dampak:** Beban server berlebih jika data ribuan.
- **Solusi:** Gunakan **Eager Loading** dan pilih kolom spesifik.
- **Prioritas:** High

Security

- **Masalah:** SQL Injection mitigation manual.
- **File & Line:** `resources/user/edit_employee.php`.
- **Dampak:** Risiko `SQLi` tinggi.
- **Solusi:** Gunakan `PDO Prepared Statements`.
- **Prioritas:** Critical

Error Handling & Logging

- **Masalah:** Menghentikan script (`die()`) di production.
- **File & Line:** `employee_detail.php` (Line 124).
- **Dampak:** UX buruk, celah bocornya informasi stack trace.
- **Solusi:** Terapkan **try-catch** global dan logger (Monolog).
- **Prioritas:** Critical

3. Prioritas Perbaikan

1. **Tahap 1 (Minggu 1):** Hapus `die()`, implementasi **try-catch**, transisi ke **Prepared Statements**.
2. **Tahap 2 (Bulan 1):** Ekstrak duplikasi HTML/JS ke komponen. Optimasi query (hapus `SELECT *`).
3. **Tahap 3 (Bulan 2-3):** Refactor arsitektur MVC, setup CI/CD dan unit testing.

4. Fitur yang Perlu Dikembangkan

- **Dashboard Analytics Real-Time:** Grafik monitoring data.
- **Sistem Notifikasi Eksternal:** Integrasi Email/WhatsApp untuk notifikasi kedaluwarsa.
- **Audit Trail Logging:** Rekam histori CRUD semua tabel.
- **Native Export Engine:** Eksportasi format XLSX *native*.

5. Roadmap Pengembangan

Fase	Waktu	Fokus Utama	Output
Phase 1: Stabilization	Bulan 1	Security & Error Handling	Sistem bebas SQLi, tidak ada die(), logging aktif.
Phase 2: Refactoring	Bulan 2	DRY Code & MVC	Query pindah ke Models, duplikasi HTML dihapus.
Phase 3: Automation	Bulan 3	Testing & CI/CD	Code coverage 40%, Auto-deploy.

6. Checklist Kesiapan Production

- ☐ Hapus flag debug di kode.
- ☐ Implementasi Centralized Error Logging.
- ☐ Konversi ke *Prepared Statements* 100%.
- ☐ Standarisasi ekspor (PDF DOMPDF/mPDF, Excel PHPSpreadsheet).
- ☐ Database Indexing pada field penting.

--- End of Audit Report ---